

AI 에이전트를 위한 MCP와 보안 기술 동향

김현지*, 윤세영*, 서화정*
*한성대학교 대학원 IT융합공학부

요약

- 최근 활발히 사용되고 있는 LLM의 AI 에이전트 기능은 보안 기능 탑재가 표준화 되어 있지 않다.
- 인증, 인가, 무결성 등의 여러 보안 위협이 발생할 위험이 있으며, 이에 대한 대응 기술을 살펴본다.

서론

- 대규모 언어 모델의 에이전트 기능은 데이터베이스, API와 같은 외부 정보로의 접근을 지원한다.
- 이를 위해 모델 컨텍스트 프로토콜 (Model Context Protocol, MCP)를 사용한다.
- 그러나, MCP는 인증, 권한 부여 및 세션 무결성을 위한 표준화된 메커니즘이 강제되지 않으므로 심각한 보안 허점을 안고 있으며, MCP 공식 문서 또한 이러한 보안 위협을 언급한다.

관련 배경

- AI 에이전트는 LLM이 외부의 데이터를 활용하여 작업을 수행하는 자율형 소프트웨어 체계
- MCP는 MCP 서버를 가지며, 에이전트 (클라이언트)와 호출 대상 도구와의 상호 작용을 지원하며, 기능 검색과 호출을 위한 프레임워크
- 그러나, MCP는 프로토콜 레벨에서의 보안 기능을 필수로 요구하지 않으며, 이로 인한 여러 보안 위협 존재
- 사칭, 권한 남용, 세션 하이재킹, 재전송 공격 등에 취약하며, 이에 대한 대응책이 필요
- MCP 기술이 2025년에 제시되었기에 이에 대한 연구들이 많지는 않으며 최근 시작되는 추세

연구 동향

- **MCP 다층 보안 프레임워크**
 - **MCP 서버에 대한 대응책**
 - TLS 1.2 이상 사용 의무화, 프롬프트 주입 및 데이터 유출에 대한 탐지 규칙 적용
 - 속도 제어를 통한 DoS 및 무차별 대입 방지
 - 사용자 인증 및 권한 부여 기능 사용
 - **클라이언트에 대한 대응책**
 - 제로 트러스트 원칙 하에 모든 상호작용을 지속 검증
 - Just-in-Time (JIT) 접근 부여로 상시 권한 제거하여 공격 표면 최소화
 - 세션 신뢰 방지 및 암호화 적용으로 인증 및 무결성 보장
- **검증 가능한 정책 기반의 AI 에이전트 프레임워크**
 - 최소 권한 원칙을 기반으로 자연어 정책을 해석 및 적용하는 방식 제시
 - 엔지니어가 작성한 보안 규칙을 프롬프트로 컴파일하여, AI 에이전트가 따라야 할 실행 규칙으로 변환
 - 해당 정책을 허용 가능/불가능 입력 또는 환각/정책 위반/데이터 유출 등의 금지된 출력으로 분류
 - 외부 사례들을 기반으로 해당 정책을 보강하여 보안 정책 생성
- **양자 내성 MCP 보안 프로토콜**
 - 인증, 인가에 대한 보안 위협 대응을 위해 양자 내성 암호 적용
 - LLM이 프롬프트 민감도를 분석하여 스스로 보안 강도를 결정하여 최적의 보안 강도를 만족하는 세션 사용
 - 인증 관련 메타 정보 (세션 식별자, 시퀀스 번호 등)을 통해 세션 하이재킹, 재전송 공격 등을 방지
 - 역할 기반 접근 제어를 통해 권한 남용 방지
 - 실험을 통해 해당 보안 프로토콜 추가에 대한 시간 오버헤드는 무시 가능한 수준임을 보임